

REPORT TECNICO

Vulnerability Assessment con Nessus – Metasploitable

Obiettivo e perimetro

L'attività consiste in un Vulnerability Assessment sulla macchina Metasploitable, eseguito con Nessus in ambiente di laboratorio. Il target utilizzato nella pratica è 192.168.60.101. La scansione è stata effettuata con la policy Basic Network Scan.

Scansione e risultato iniziale

La scansione iniziale ha evidenziato una superficie di rischio ampia, con numerose vulnerabilità Critical, High e Medium.

Filter	Search Vulnerabilities			70 Vulnerabilities			
Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	CRITICAL	10.0		Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
☐	CRITICAL	10.0 *		VNC Server 'password' Password	Gain a shell remotely	1	
☐	CRITICAL	9.8		SSL Version 2 and 3 Protocol Detection	Service detection	2	
☐	CRITICAL	9.8		Bind Shell Backdoor Detection	Backdoors	1	
☐	MIXED	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
☐	CRITICAL	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
☐	HIGH	7.5	4.9	0.3693 Samba Badlock Vulnerability	General	1	
☐	HIGH	7.5 *	4.9	0.119 rlogin Service Detection	Service detection	1	
☐	HIGH	7.5 *	4.9	0.119 rsh Service Detection	Service detection	1	
☐	HIGH	7.5		NFS Shares World Readable	RPC	1	
☐	MIXED	...	...	SSL (Multiple Issues)	General	28	
☐	MIXED	...	...	ISC Bind (Multiple Issues)	DNS	5	
☐	MEDIUM	6.5		TLS Version 1.0 Protocol Detection	Service detection	2	
☐	MEDIUM	6.5		Unencrypted Telnet Server	Misc.	1	

Risultato della scansione Nessus e panoramica delle vulnerabilità rilevate.

Parametro	Valore
Target	192.168.60.101
Policy	Basic Network Scan
Vulnerabilità iniziali	70
Scanner	Local Scanner

Vulnerabilità analizzate

Finding	Severità	CVSS	Porta/servizio	Remediation sintetica
Canonical Ubuntu Linux SEoL (8.04.x)	Critical	10.0	80/tcp	Aggiornare a OS supportato
VNC Server 'password' Password	Critical	10.0	5900/tcp	Password forte / eliminare default
SSL Version 2 and 3	Critical	9.8	25/tcp, 5432/tcp	Disabilitare SSLv2/SSLv3
Bind Shell Backdoor Detection	Critical	9.8	1524/tcp	Rimuovere bind shell e verificare integrità
Apache Tomcat SEoL (<=5.5.x)	Critical	10.0	8180/tcp	Aggiornare Tomcat
Tomcat AJP Request Injection (Ghostcat)	Critical	9.8	8009/tcp	Aggiornare e proteggere/disabilitare AJP

Evidenze Nessus

Vulnerabilities 70

CRITICAL VNC Server 'password' Password

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution
Secure the VNC service with a strong password.

Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host

Port	Hosts
5900 / tcp / vnc	192.168.60.101

Plugin Details

Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015

Risk Information

Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/Ca:C/A:C

Vulnerability Information

Default Account: true
Exploited by Nessus: true

Nessus: Ubuntu 8.04 identificato come sistema operativo fuori supporto.

Metasploitable scansioni completa / Plugin #201352

Hosts 1 **Vulnerabilities 70** Remediations 2 Notes 2 History 3

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.nessus.org/u/73bdb2d2e>

Output
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2012
Time since Security End of Life (Est.) : >= 13 years
To see debug logs, please visit individual host

Port	Hosts
10 / tcp / www	192.168.60.101

Plugin Details

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/CH:H/HA:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/Ca:C/A:C

Vulnerability Information

CPE: cpe:/o:canonical:ubuntu_linux
Unsupported by vendor: true

Nessus VNC sulla porta 5900/tcp con password debole 'password'.

Hosts 1 **Vulnerabilities 70** Remediations 2 Notes 2 History 3

CRITICAL SSL Version 2 and 3 Protocol Detection

Description
The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:
- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.
An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.
Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.
NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution
Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also
<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<http://www.nessus.org/u/b06c7e95>
<http://www.nessus.org/u/247c4540>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<http://www.nessus.org/u/5d15ba70>

Plugin Details

Severity: Critical
ID: 20007
Version: 1.35
Type: remote
Family: Service detection
Published: October 12, 2005
Modified: April 13, 2026

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/CH/H/HA:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/Ca:C/A:C

Vulnerability Information

In the news: true

Nessus Bind Shell Backdoor sulla porta 1524/tcp; l'output mostra uid=0(root).

Output Nessus was able to exploit the issue using the following request : 0x0000: 02 02 00 08 48 54 50 2F 31 2E 31 00 00 0F 2F ...HTTP/1.1.../ 0x0010: 61 73 44 46 2F 78 78 78 78 2D 6A 73 70 00 00 ..andfxxxxxx.jsp.. 0x0020: 09 6C 67 63 61 6C 68 6F 73 74 00 FF 08 09 6C ..localhost:..1 0x0030: 6F 63 61 6C 68 6F 73 74 00 50 00 09 0A 04 ..ocalhost:P..... 0x0040: 00 0B 65 65 70 2D 61 6C 69 76 65 00 00 41 ..Keep-alive:..A 0x0050: 63 65 70 74 2D 4C 61 6E 67 75 61 67 65 00 ..compt-Language.. Host:.. .. To see debug logs, please visit individual host <table><thead><tr><th>Port #</th><th>Hosts</th></tr></thead><tbody><tr><td>109 /tcp/ip13</td><td>192.168.60.101</td></tr></tbody></table> <td data-bbox="1206 151 1362 321"> Exploit Prediction Scoring (EPS): T9.9 Risk Factor: High CVSS v3.0 Base Score: 9.8 CVSS v3.0 Vector: CVSS:3.0/AW/NIAC/L/PR:N/UI:N/SU:C/H/H/A/H CVSS v3.0 Temporal Vector: CVSS:3.0/EH/RLO/F/RC/C CVSS v3.0 Spatial Score: 9.4 CVSS v2.0 Base Score: 7.5 CVSS v2.0 Temporal Score: 6.5 CVSS v2.0 Vector: CVSS2#AW/NIAC/L/AL/N/C/P/H/P/A/P CVSS v2.0 Temporal Vector: CVSS2#E/H/RLO/F/RC/C Vulnerability Information CPE: cpe:/a:apache:tomcat Exploit Available: true Exploit Ease: Exploits are available Patch Pub Date: March 1, 2020 Vulnerability Pub Date: March 1, 2020 Exploited by Nessus: true Reference Information CVE-ID: CVE-2020-0021 CISA-KNOWN-EXPLOITED: 2022/03/17 CVE: CVE-2020-1745, CVE-2020-1938 </td>	Port #	Hosts	109 /tcp/ip13	192.168.60.101	Exploit Prediction Scoring (EPS): T9.9 Risk Factor: High CVSS v3.0 Base Score: 9.8 CVSS v3.0 Vector: CVSS:3.0/AW/NIAC/L/PR:N/UI:N/SU:C/H/H/A/H CVSS v3.0 Temporal Vector: CVSS:3.0/EH/RLO/F/RC/C CVSS v3.0 Spatial Score: 9.4 CVSS v2.0 Base Score: 7.5 CVSS v2.0 Temporal Score: 6.5 CVSS v2.0 Vector: CVSS2#AW/NIAC/L/AL/N/C/P/H/P/A/P CVSS v2.0 Temporal Vector: CVSS2#E/H/RLO/F/RC/C Vulnerability Information CPE: cpe:/a:apache:tomcat Exploit Available: true Exploit Ease: Exploits are available Patch Pub Date: March 1, 2020 Vulnerability Pub Date: March 1, 2020 Exploited by Nessus: true Reference Information CVE-ID: CVE-2020-0021 CISA-KNOWN-EXPLOITED: 2022/03/17 CVE: CVE-2020-1745, CVE-2020-1938
Port #	Hosts				
109 /tcp/ip13	192.168.60.101				

Vulnerabilities

79

CRITICAL

Bind Shell Backdoor Detection

<

>

Plugin Details

Severity: Critical

ID: 51988

Version: 1.10

Type: remote

Family: Backdoors

Published: February 15, 2011

Modified: April 11, 2022

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

```

Nessus was able to execute the command "id" using the
following request :

this produced the following truncated output (limited to 10 lines) :
..... anip
root@metasploitable/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable/#
..... anip

```

To see debug logs, please visit individual host

Port	Hosts
1524/tcp/wild_shell	192.168.60.101

Risk Information

Risk Factor: Critical

CVSS v3.0 Base Score: 9.8

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Remediation VNC eseguita

```
msfadmin@metasploitable:~$ sudo kill -HUP 4436
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
msfadmin@metasploitable:~$
```

Verifica del processo Xtightvnc e della configurazione VNC.

```
msfadmin@metasploitable:~$ sudo -u msfadmin /usr/bin/vncpasswd /home/msfadmin/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
Cannot write password file /home/msfadmin/.vnc/passwd
msfadmin@metasploitable:~$
```

Verifica del file ~/.vnc/passwd e dei relativi permessi.

```
msfadmin@metasploitable:~$ sudo ls -la /home/msfadmin/.vnc/
total 68
drwx----- 2 root    root    4096 2026-10-03 10:54 .
drwxr-xr-x  9 msfadmin msfadmin 4096 2026-10-03 10:54 ..
-rw-r--r--  1 root    root    34723 2026-10-03 17:40 metasploitable:0.log
-rw-r--r--  1 root    root      5 2026-10-03 10:54 metasploitable:0.pid
-rw-r--r--  1 root    root    8114 2026-10-03 10:23 metasploitable:1.log
-rw-r--r--  1 root    root      5 2026-10-03 10:23 metasploitable:1.pid
-rw-----  1 root    root      8 2026-10-02 16:38 passwd
-rwxr-xr-x  1 root    root    151 2026-10-02 16:38 xstartup
msfadmin@metasploitable:~$
```

Correzione dei permessi/ownership e riavvio di xinetd.

Hosts 1 Vulnerabilities 58 Remediations 3 Notes 1 History 4								
Filter Search Vulnerabilities 58 Vulnerabilities								
Sev	CVSS	VPR	EPSS	Name	Family	Count		
☐ CRITICAL	10.0 *	7.9	0.8353	UnrealIRCd Backdoor Detection	Backdoors	1	☐	☒
☐ CRITICAL	10.0 *	5.8	0.7072	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness	Gain a shell remotely	1	☐	☒
☐ CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	☐	☒
☐ MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	☐	☒
☐ HIGH	7.5	4.9	0.3093	Samba Badlock Vulnerability	General	1	☐	☒
☐ HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	☐	☒
☐ HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	☐	☒
☐ HIGH	7.5			NFS Shares World Readable	RPC	1	☐	☒
☐ MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	☐	☒
☐ MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1	☐	☒
☐ MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6	☐	☒
☐ MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	5	☐	☒

Scan Details

Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 9:30 AM
End: Today at 9:50 AM
Elapsed: 20 minutes

Vulnerabilities

Critical
High
Medium
Low
Info

Verifica finale: il servizio VNC risulta nuovamente in ascolto sulla porta 5900/tcp.

Nota: il riavvio e la verifica della porta confermano che il servizio è attivo; la validazione definitiva della vulnerabilità deve essere effettuata tramite una nuova scansione Nessus.

Scansione post-remediation

Il numero complessivo è passato da 70 a 58 finding, con una riduzione di 12 finding (circa 17,1%). Il risultato dimostra un miglioramento, ma non la risoluzione completa della superficie di rischio.

Raccomandazioni

- Aggiornare il sistema operativo fuori supporto.
- Aggiornare Apache Tomcat e mettere in sicurezza il connettore AJP.
- Eliminare la bind shell e verificare l'integrità del sistema.
- Disabilitare SSLv2/SSLv3 e utilizzare TLS moderno.
- Gestire VNC con credenziali robuste e limitare l'esposizione del servizio.
- Ripetere Nessus dopo ogni remediation significativa.

Conclusione

L'esercizio ha permesso di completare il ciclo vulnerability assessment → analisi → remediation → verifica. Le vulnerabilità Critical devono avere priorità assoluta in un eventuale ambiente produttivo.